

Data questions of use cases

Data-access assumption (already decided): full partner telemetry remains under partner control. Observations 2.0 queries approved partner datasets, selectively materializes relevant results, and preserves partner, source-system, query, coverage, and handling metadata throughout processing.

Questions below do not re-ask that. They do not assume the *contents* of an approved dataset (direction, blocks, product versions, dispositions, and so on). For each use case, ask whether those facts will be in what we can query, how the term is defined, and what the analyst is supposed to receive.

Across all 12

1. **Will the approved dataset contain the fact the scenario depends on** (blocked, exploited, same app, dormant, disposition), or only that something related was returned?
2. **How is the joining term defined** (bad IP, same product, same campaign, same vendor, same behavior)?
3. **How should partner-specific severity/posture be shown vs rolled up** for our threat analyst?

1. BadIP1 — same infrastructure, different risk

Partner A blocks inbound from a bad IP; Partner B has an established outbound connection to it. Same indicator, opposite direction and severity. A gets “keep blocking / review history”; B gets an urgent compromise hunt.

We can do: differentiated warning (blocked inbound vs live outbound). Partner can do: hunt/contain the outbound host.

Questions

- Will we know whether the indicator was **blocked**, or only that it was **observed**?
- Will we know **direction** (inbound vs outbound) and whether a connection was **attempted vs established**?
- How is **bad IP** defined? Threat-intel list, our scoring, a partner disposition, or something else? Who is allowed to apply that label, and when can it change?
- If two partners send the same IP, what makes that **the same entity** for us vs two unrelated uses of the same address?
- How will we **separate severities among partners**, and how should that be **aggregated for our threat analyst** (one case with partner-specific rows, two products, a rollup score, etc.)?
- What does “review history” require us to have: prior hits from that partner, from all partners, or only what arrived with the current event?

2. Shared vulnerability exploitation

Scanning, exploitation, and unpatched exposure of the same product appear at different partners. Combined evidence turns a CVE into an active-exploitation warning with partner-specific priority (investigate vs. patch now).

We can do: active-exploitation picture and who is exposed. Partner can do: investigate compromise / patch.

Questions

- Will we know the difference between **scanning**, **exploit attempt**, and **successful exploitation**, or only that a vulnerability-related event occurred?
- How is **same product** / **same vulnerability** defined across partners (name, version, CVE, or partner-supplied tag)?
- Will we know whether a partner **has the affected product/version**, or only whether they reported related activity?
- How do we turn that into partner-specific direction (investigate vs patch vs monitor) **without assuming we can see their patch state**?
- For the analyst, is this one vulnerability case with three partner postures, or three cases tied together? What is the rollup?

3. Campaign reconstruction

Credential stuffing, a successful login, PowerShell persistence, and C2 to a new domain land at four partners. The federation stitches a full kill chain and issues compromise alerts, a preventive warning, and a hunt package.

We can do: stitch the kill chain; hunt package. Partner can do: confirm and interrupt their stage.

Questions

- What is allowed to **link** those events as one campaign? Same indicator, same time window, partner assertion, analyst decision, or a rule we still need to define?
- How is **related infrastructure** defined if the indicators are not the same?
- If a stage is missing, do we still call it a campaign, a partial picture, or unknown?
- Who confirms “this is one operation,” and what does the analyst see when partners only each have one fragment?

4. Control effectiveness

The same malicious attachment is blocked at email, blocked at endpoint, or allowed through to compromise. The community learns which defenses actually worked, not just which IOCs to share.

We can do: which defenses actually worked. Partner can do: adopt the working control; remediate the miss.

Questions

- How do we know it is the **same attachment** (hash, family, partner-supplied ID, or something else)?
- Will we know **where** it was stopped (gateway vs endpoint vs not stopped), or only that a malware event existed?
- How is **effective** defined: blocked, not executed, no later incident, or partner says it was a win?
- Will we get **outcome** / **disposition**, or only the original detection?
- If partners have different stacks, what are we allowed to compare, and what should we not claim?
- For the analyst, do we present “this control worked here” as evidence, a recommendation, or both? What is the community rollup vs the partner-specific note?

5. Weak-signal detection

A few failed logins to dormant accounts, password resets, and one successful inactive-account login look routine alone. Together they look like a coordinated identity campaign, early enough to act.

We can do: early campaign call from small events. Partner can do: review dormant accounts and resets.

Questions

- How is **dormant / inactive** defined, and will that definition be in what we receive?
- Will we know **failed vs successful** authentication, and password-reset vs login, as separate facts?
- What counts as **similar accounts** across partners?
- What is “a small number,” and against what baseline? Do we have a baseline, or do we need one as a requirement?
- How many partners, and what similarity, before we escalate from noise to campaign?
- For the analyst: one early-warning object with low-confidence partner rows, or a collection request with no severity until more arrives?

6. Infrastructure rotation

Beaconing to Domain1, Domain2, and a new IP share timing, process, and protocol. Behavior tracking survives IOC churn.

We can do: behavior-based tracking past IOC churn. Partner can do: hunt the new domain/IP locally.

Questions

- Will we have **timing / sequence / process** information, or only changing indicators?
- How is **same behavior** defined well enough to join Domain1, Domain2, and a new IP?
- Who decides two different indicators are the same campaign: us, the partner, intel, or the analyst?
- If we only have the indicators and not the behavior, what are we allowed to say?
- When we propose a **new provisional indicator**, how is that labeled vs a confirmed one?
- How should the analyst see this: one campaign with rotating indicators, or separate IOCs with a “possibly related” flag?

7. AI-assisted phishing (uncertain assessment)

Unique, role-tailored, rapidly adapting lures appear across partners, with no smoking-gun AI artifact. The product is a formal likelihood/confidence judgment, alternatives, and behavioral guidance—not a wait for definitive attribution.

We can do: evidence-based assessment, not attribution. Partner can do: change mail/user detection to behavior, not templates.

Questions

- Will we receive **message content, headers, both, or only partner assessments**?
- How is **highly personalized / role-tailored** determined if we may not have the body or the recipient role?
- What would count as evidence for **AI-assisted**, and what would count against it?
- Do we need a requirement to store **analyst likelihood/confidence and alternatives**, since this may never get a hard label?
- How do we know later messages are the **same campaign** if every lure is unique?
- For the analyst: an assessment object (judgment + evidence + alternatives) rather than a detection. What severity, if any, attaches to that?

8. Sector-wide reconnaissance

Several partners see scanning against the same remote-access tech; another deploys it but sees nothing; another cannot collect the telemetry. The system distinguishes **not observed**, **not exposed**, and **unable to determine**.

We can do: next-likely targets vs coverage holes. Partner can do: mitigate if exposed; collect if blind.

Questions

- How do we know partners are talking about the **same technology**?
- Will we know **who uses it**, independently of who reported scanning?
- Given coverage metadata is preserved, how should **not observed**, **not exposed**, and **unable to determine** be defined and shown so they stay distinct for the analyst?
- What are we required to show so a partner with no returned events cannot be read as all-clear?

9. Cloud identity abuse

Impossible travel + suspicious OAuth consent in one tenant, the same app ID reading mailboxes in another, the same integration unused-but-present in a third. Cross-tenant identity campaign, with token-hunt guidance for the not-yet-hit partner.

We can do: cross-tenant app/consent pattern. Partner can do: revoke tokens; inspect the integration.

Questions

- Will we receive **application IDs**, **consent events**, and **mailbox-access events**, or only a partner's "identity alert"?
- How is **impossible travel** defined in what we get, and do we treat that as fact or as the partner's judgment?
- How is **same application** defined across tenants?
- Will we know whether C **has that integration**, or only whether C reported an anomaly?
- For the analyst: one identity-campaign case with partner postures (compromised / same app seen / exposed not observed). How is severity split vs rolled up?

10. Cloud control-plane attack

IAM expansion, logging disabled, and a new key plus storage enumeration from related infrastructure in a short window. Looks like unrelated cloud change locally; looks coordinated malicious administration together.

We can do: coordinated admin vs routine change. Partner can do: respond in the cloud account.

Questions

- Will we know these as **distinct admin actions**, or only as generic cloud alerts?
- How is **unusual** / **unexpected** defined: partner label, our baseline, or change-management we may not have?
- What makes the infrastructure **related**, and what is the **time window**?
- If we do not receive approved-change context, what are we allowed to claim vs what must stay "possibly related admin activity"?
- How do we avoid treating normal cloud operations as coordination?
- For the analyst: one coordinated-admin case or three partner events with a relatedness score? What aggregation is actually useful?

11. Detection validation

A new analytic fires as rare-and-interesting, as a known software update, and as a true compromise. Community outcomes tune the rule (filters, prerequisites, where it can even run) before wide deployment.

We can do: TP/FP conditions before wide deploy. Partner can do: deploy, suppress, or add telemetry.

Questions

- Will we receive **rule identity/version** and the fact that it fired, or only the underlying events?
- Will we get **analyst disposition** (true positive, false positive, benign, incident)?
- How is **same sequence** defined if partners do not send the rule logic?
- What should we promote back: a better rule, a suppression, partner-specific guidance, or only a validation report?
- For the analyst: how do we aggregate “works here / false positive there / confirmed there” without turning into a single misleading precision number?

12. Third-party / supply-chain warning

Suspicious MSP-account use, an unexpected vendor-signed update, and privileged vendor access with no anomaly yet. Shared dependency is the linking key; the warning can name the risk without dumping partner-sensitive detail.

We can do: shared vendor risk without dumping partner detail. Partner can do: investigate MSP/vendor path; lock it down.

Questions

- How is the **vendor / MSP** identified so A, B, and C can be joined? Will that identifier actually be in the data?
- Will we know **privileged / trusted access** as a fact we receive, or only inferred from the event?
- How is **unexpected** update defined, and will we have anything to compare it against?
- What can the **community warning** include so it names the shared dependency without exposing partner-sensitive relationships?
- For the analyst: one third-party risk case with partner-specific actions. How is that aggregated when only A and B have events and C is exposure-only?